

SOC Security Operation Center Issues

Einführung

SOC.F2601

Peter Infanger, HSLU I



Bildquelle: <https://securityaffairs.com/47631/breaking-news/soc-security-operations-center.html>

Programm

- Was ist ein SOC?
- Was tut ein SOC (und was nicht)?
- Referenzmodelle / Frameworks
- Wieso braucht man überhaupt ein SOC?
- Bedrohungen
- Elemente des SOC
- Metriken
- Security vs. Availability
- Strategie & Betriebsmodelle

Was ist ein SOC

Security Operations



What Is a SOC?

A security operations center, or SOC, is a physical room or area in an organization's office where cybersecurity analysts work to monitor enterprise systems; defend against security breaches; and identify, investigate and mitigate cybersecurity threats.

SOCs were created to facilitate collaboration among security personnel. They streamline the security incident handling process as well as help analysts triage and resolve security incidents more efficiently and effectively.



What is a Security Operations Center (SOC)?

The function of the security operations center (SOC) is to monitor, prevent, detect, investigate, and respond to cyber threats around the clock. SOC teams are charged with monitoring and protecting the organization's assets including intellectual property, personnel data, business systems, and brand integrity. The SOC team implements the organization's overall cybersecurity strategy and acts as the central point of collaboration in coordinated efforts to monitor, assess, and defend against cyberattacks.

CompTIA

What Is a Security Operations Center?

Simply put, a security operations center (SOC – pronounced “sock”) is a team of experts that proactively monitor an organization's ability to operate securely. Traditionally, a SOC has often been defined as a room where SOC analysts work together. While this is still the case in many organizations, the advent of COVID-19 and other factors has led the SOC team to be more remotely distributed. Increasingly, today's SOC is less a single room full of people, and more of an essential security function in an organization.

A SOC team member can often function just as well working out of their home office as they can in a physical security operations center.



What is a Security Operations Center (SOC)?

What is a SOC? A [security operations center](#), or SOC, is a team of IT security professionals that protects the organization by monitoring, detecting, analyzing, and [investigating cyber threats](#). Networks, servers, computers, endpoint devices, operating systems, applications and databases are continuously examined for signs of a cyber security incident. The SOC team analyzes feeds, establishes rules, identifies exceptions, enhances responses and keeps a look out for new vulnerabilities.

Given that technology systems in the modern organization run 24/7, SOC's usually function around the clock in shifts to ensure a rapid response to any emerging threats. SOC teams may collaborate with other departments and employees or work expert third party IT security providers.

Before setting up an SOC, organizations must develop an overarching cyber security strategy that aligns with their business objectives and challenges. Many large organizations have an in-house SOC but others opt to outsource the SOC to a third-party managed security services providers.

Security intelligence and operations consulting services include an arsenal of security solutions to stay ahead of security threats.

Was ist ein SOC?

- Team von Security Spezialisten
- örtlich meist zusammengezogen
→ inhouse oder extern
- kann Teil des IT-Infrastruktur- bzw. Operations- Team oder NOCs (Network Operation Center) sein
- üblicherweise unter dem CIO oder CISO angegliedert und rapportiert diesen

Was tut ein SOC?

- Ergebnisse einer SANS-Umfrage
im 2019

Quellen:

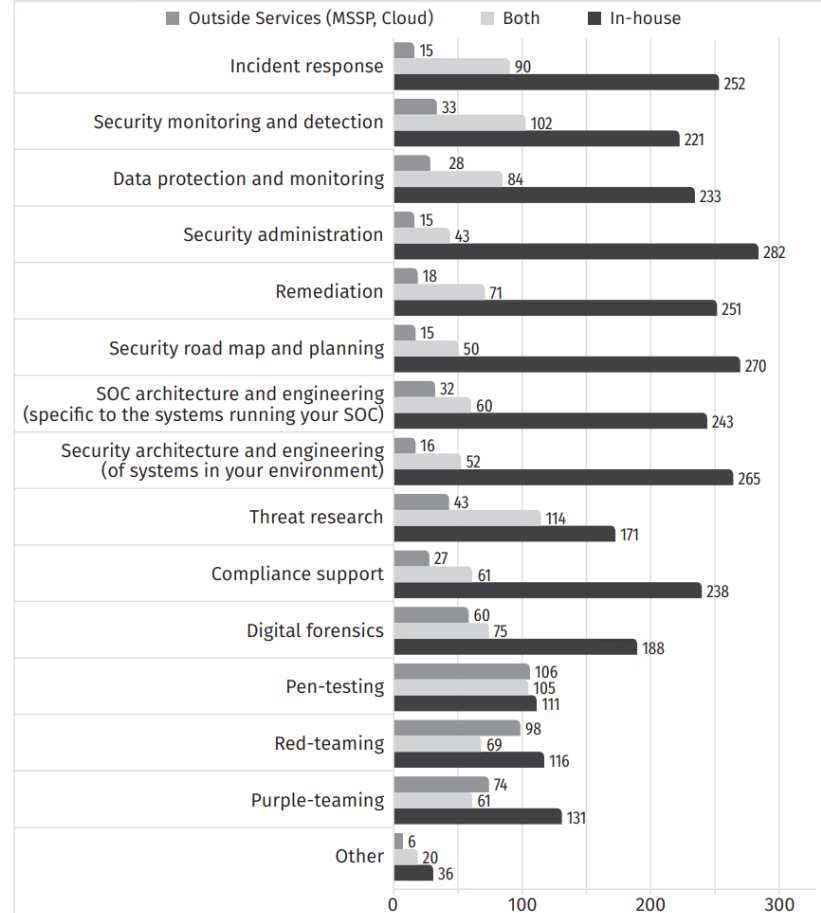
<https://www.sans.org/reading-room/whitepapers/analyst/common-practices-security-operations-centers-results-2019-soc-survey-39060>

<https://www.crowdstrike.com/en-us/resources/guides/complete-guide-to-next-gen-siem/>

Slide 5

What activities are part of your SOC operations? What activities have you outsourced, either totally or in part, to outside services through a managed security service provider (MSSP) or in the cloud?

Leave blank those that do not apply. (N=360)



Was tut ein SOC

Kernpunkte:

- Monitoring → Überwachen
 - Detection → Erkennen
 - Investigation → Untersuchen
 - Remediation → Beheben/Sanieren
 - Responding to Incidents → auf Ereignisse reagieren
-
- Hilft bei Security Architecture & Engineering
 - Unterstützt in *Compliance-Fragen
 - ...



*Compliance: Regeltreue von Unternehmen, also die Einhaltung von Gesetzen, Richtlinien, etc.

Was tut ein SOC nicht?

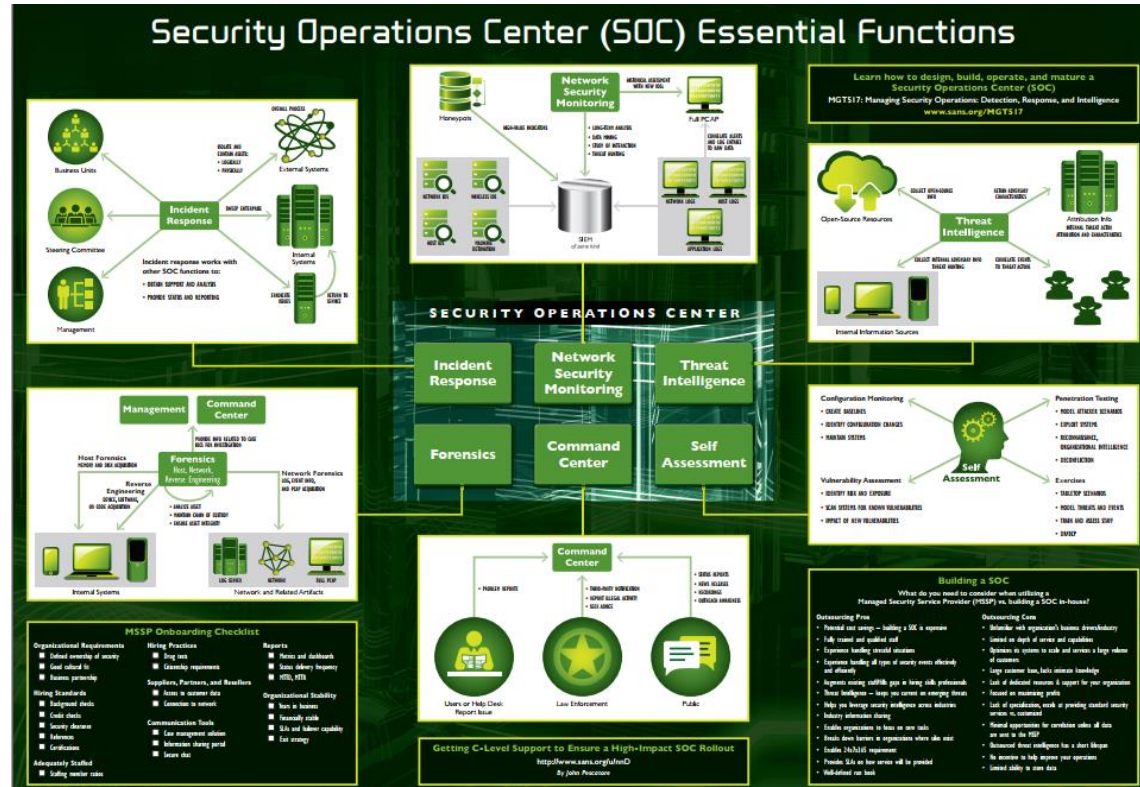
- Betreiben von Sicherheitskomponenten wie Firewall, Proxy, ...
- PC nach einem Incident frisch aufsetzen
- Security Audits machen
- Sicherheitsarchitektur einer Unternehmung festlegen
- Gebäude sichern
- Business Continuity Planning
- Sicherheitsberatung der Endbenutzer
- ...



Referenzmodelle & Frameworks

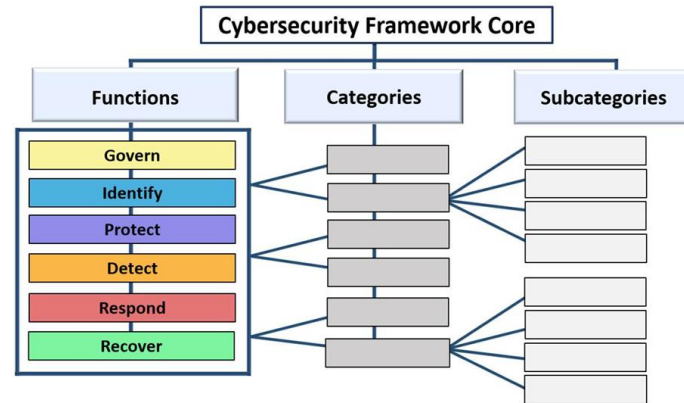
Aufgrund der Komplexität, welche ein SOC aufweisen kann, werden zur Vereinfachung gerne Referenzmodelle verwendet

- ## - SANS SOC Essential Functions

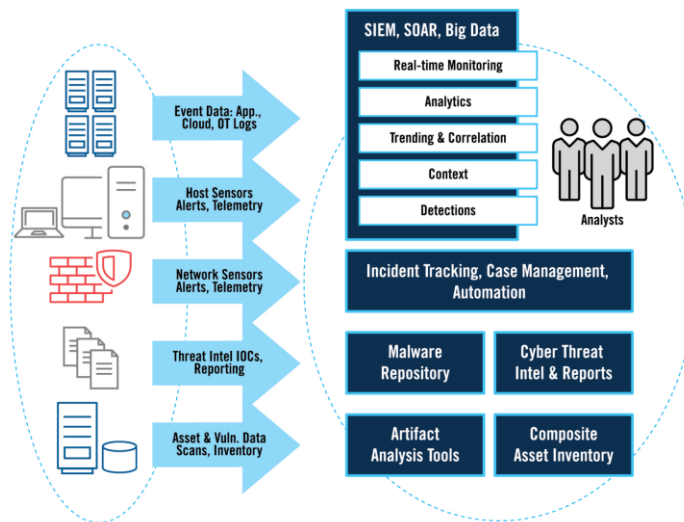


Referenzmodelle & Frameworks

- NIST Cybersecurity Framework (CSF) 2.0
<https://www.nist.gov/cyberframework>
- MITRE:
<https://www.mitre.org/sites/default/files/2022-04/11-strategies-of-a-world-class-cybersecurity-operations-center.pdf>
- OWASP:
[https://wiki.owasp.org/index.php/OWASP_Security_Operations_Center_\(SOC\)_Framework_Project](https://wiki.owasp.org/index.php/OWASP_Security_Operations_Center_(SOC)_Framework_Project) (archiviert)

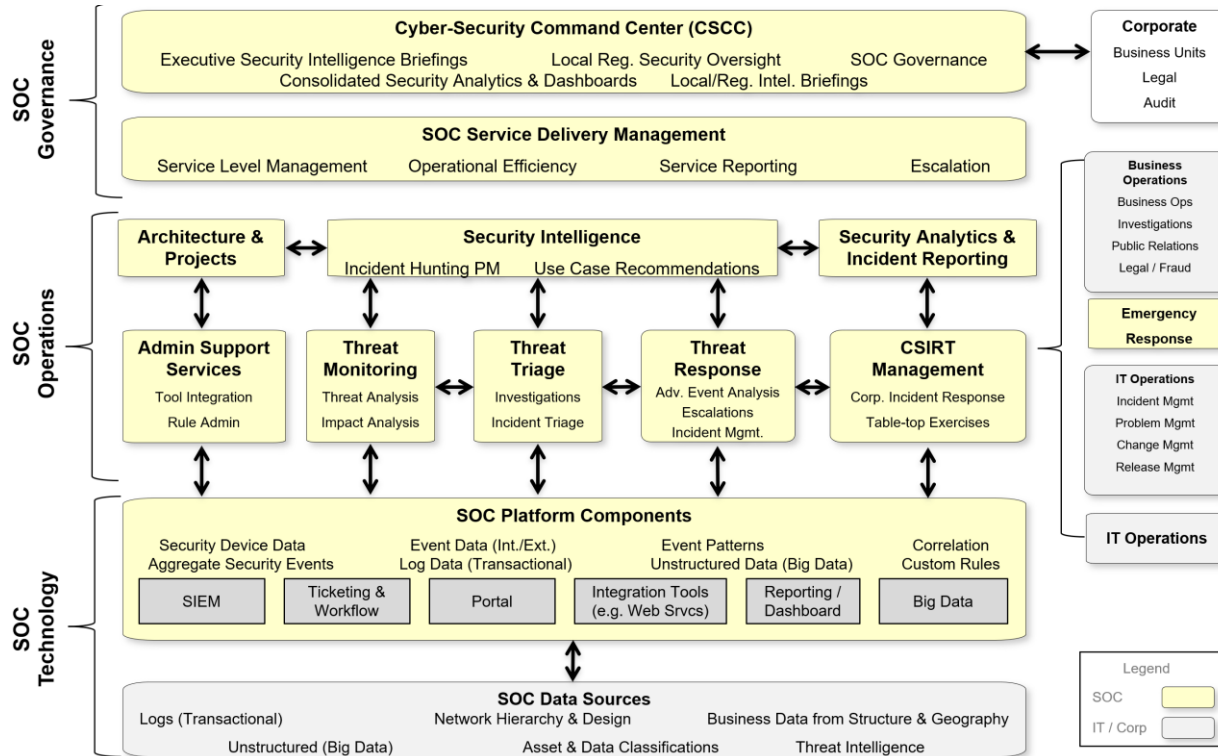


CSF Core structure



Typical SOC Data and Tools

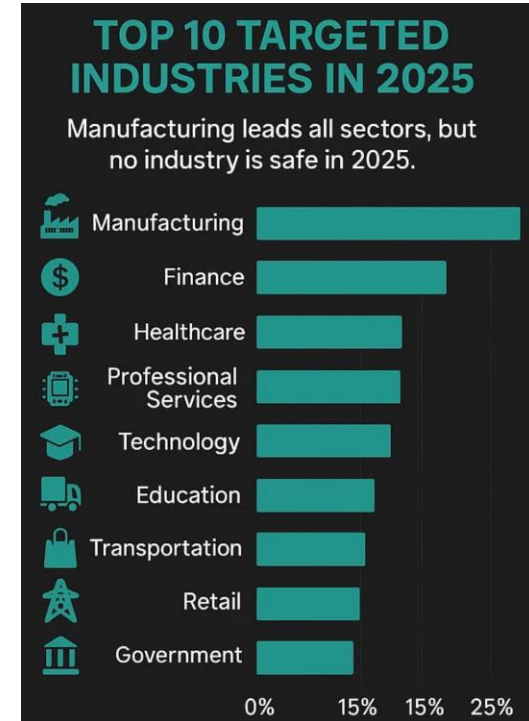
Referenzmodelle & Frameworks



Weshalb braucht es ein SOC?

- Stichwort: Threats / Bedrohungen
- Cyberthreats nehmen laufend zu
- *Vulnerabilities (Schwachstellen) nehmen zu und zwar in den meisten Bereichen
- Besonders betroffen sind Bereiche mit geringer Security Awareness (also nicht gut vorbereitet) und KMU

*siehe: <https://www.ibm.com/downloads/cas/ADLMYLAZ>



Weshalb braucht es ein SOC?

- Cyberkriminalität ist heute ein Geschäftsmodell!
- Es entwickelt sich zu einem eigentlichen Industriezweig*
- Finanzielle Schaden kennt nur eine Richtung**: aufwärts

* <https://www.vikingcloud.com/blog/cybersecurity-statistics>

** <https://www.bdemerson.com/article/complete-cybercrime-statistics>



Woher kommen die Bedrohungen

Amateurs

Hacktivists

Financial Gain

Trade Secrets and Global Politics

- Zu den Bedrohungsakteuren gehören unter anderem Amateure, Haktivisten, organisierte kriminelle Gruppen, staatlich gesponserte und terroristische Gruppen.
- Bedrohungsakteure sind Einzelpersonen oder Gruppen von Einzelpersonen, die Cyberangriffe durchführen.
- Cyberangriffe sind absichtliche, böswillige Handlungen, die darauf abzielen, eine andere Person oder Organisation negativ zu beeinflussen.

Woher kommen die Bedrohungen

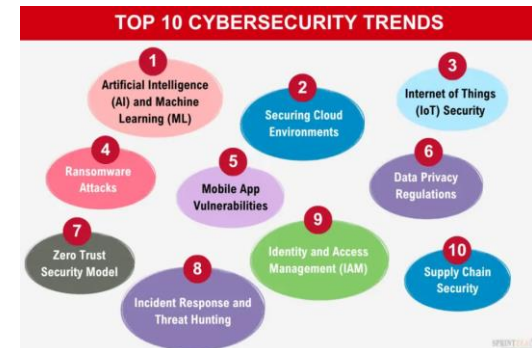
- **Amateure**, auch Skript-Kiddies genannt, verfügen über wenig oder gar keine Kenntnisse. Sie verwenden oft vorhandene Tools oder im Internet gefundene Anleitungen, um Angriffe zu starten. Manche sind einfach nur neugierig, während andere versuchen, ihre Fähigkeiten zu demonstrieren, indem sie Schaden anrichten. Auch wenn sie einfache Tools verwenden, können die Ergebnisse dennoch verheerend sein.
- **Haktivisten** sind Hacker, die gegen eine Vielzahl von politischen und sozialen Ideen protestieren. Hacktivist*innen protestieren öffentlich gegen Organisationen oder Regierungen, indem sie Artikel und Videos veröffentlichen, sensible Informationen durchsickern lassen und Webdienste mit illegitimem Datenverkehr in verteilten Denial-of-Service-Angriffen (DDoS) stören.

Woher kommen die Bedrohungen

- Ein Grossteil der Hacking-Aktivitäten, die unsere Sicherheit immer wieder bedrohen, ist durch finanziellen Gewinn motiviert. Diese **Cyber-Kriminellen** wollen Zugang zu unseren Bankkonten, persönlichen Daten und allem anderen, was sie nutzen können, um Geld zu verdienen.
- In den letzten Jahren haben wir viele Geschichten über Nationalstaaten gehört, die andere Länder hacken oder sich anderweitig in die Innenpolitik einmischen. Nationalstaaten sind auch daran interessiert, den Cyberspace für Wirtschaftsspionage zu nutzen. Der Diebstahl von geistigem Eigentum kann einem Land einen erheblichen Vorteil im internationalen Handel verschaffen.

Die Verteidigung gegen die Folgen von staatlich gesponserter Cyberspionage und Cyberkriegsführung wird weiterhin eine Priorität für Cybersecurity-Experten sein.

Quelle: <https://www.sprintzeal.com/blog/cybersecurity-trends>



Leider gibt es keine App dafür ☹️

"SOC in an App"

The screenshot displays the IBM Security Service configuration interface. It features several sections with adjustable settings:

- Client Success**: Includes a dropdown menu labeled "Undefined" with a right arrow.
- Compliance & Reporting**: Includes a dropdown menu with a right arrow.
- Technology Scope**: A blue header bar.
- Log Integrity, Firewall, IDPS, Identity & Access, DLP, Application Monitoring, Brand Monitoring**: A row of seven toggle switches. "Log Integrity", "Firewall", and "IDPS" are turned on (blue). "Identity & Access", "DLP", "Application Monitoring", and "Brand Monitoring" are turned off (grey).
- People**: A blue header bar.
- In-House, Co-Deliver, Outsource**: A row of three toggle switches. "In-House" and "Co-Deliver" are turned on (blue). "Outsource" is turned off (grey).
- Functionality**: A blue header bar.
- Security Intelligence, Compliance Management, Device Management, Policy Management**: A column of four toggle switches. "Security Intelligence" is turned on (purple). "Compliance Management", "Device Management", and "Policy Management" are turned off (grey).
- Security Monitoring, Correlation Rules, Incident Escalation, Incident Response**: A column of four toggle switches. "Security Monitoring", "Correlation Rules", and "Incident Escalation" are turned on (purple). "Incident Response" is turned off (grey).
- Escalations & Notifications**: Includes a dropdown menu with a right arrow.

Quelle: IBM Security Service

....Don't be a **FOOL** and think you just need to buy a **TOOL**

oder



Soweit sind wir noch nicht 😊

und werden es wahrscheinlich auch nie sein ☹

Quelle: <https://dilbert.com/strip/2015-06-25> (leider offline)

Elemente eines SOC

Die wichtigsten Elemente eines SOC sind: **PPT**

- Mitarbeiter (People)
- Technologien (Technology)
- Prozesse (Processes)



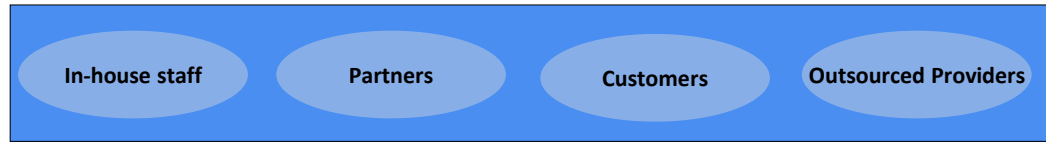
Die Verteidigung gegen aktuelle Bedrohungen

erfordert einen **formalisierten**, **strukturierten** und **disziplinierten** Ansatz.

Unternehmen nutzen in der Regel die Dienste von Experten in einem Security Operations Center (SOC).

SOCs bieten ein breites Spektrum an Dienstleistungen, von der Überwachung und Verwaltung bis hin zu umfassenden Bedrohungslösungen und ge-hosteter Sicherheit, die an die Bedürfnisse des Kunden angepasst werden können.

SOCs können vollständig **intern** sein, sich im Besitz eines Unternehmens befinden und von diesem betrieben werden. Elemente oder sogar das ganze SOC kann an **externe** Sicherheitsdienstleister vergeben werden.



SOC-Mitarbeiter

- Das SOC ist nur so gut wie seine Mitarbeiter!
- Eine frühzeitige Planung der Personalmanagement-Aspekte einer 24x7 sicherheitszentrierten Organisation wird sich langfristig auszahlen.

Zu beachten:

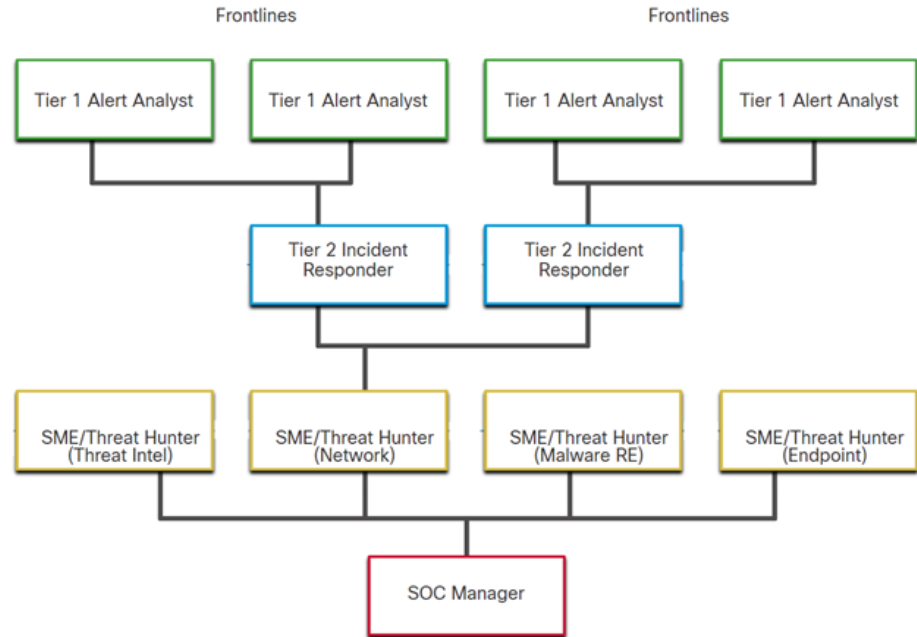
- SOC-Mitarbeiter haben spezielle Fähigkeiten und erfahrene Mitarbeiter sind oft schwer zu finden.
- Schulungen sind teuer, zeitaufwendig und verbessern die Marktfähigkeit der Mitarbeiter. Die Vergütungsstrategien müssen entsprechend bewertet werden.
- Die Bindung von Mitarbeitern ist in einer nicht sicherheitsorientierten Organisation schwierig, da ständig neue Schulungen erforderlich sind, es keine weitreichenden Karriereöglichkeiten gibt und die Mitarbeiter ausbrennen.
- Neben den Analysten für die 24x7-Abdeckung müssen auch andere unterstützende Funktionen in Betracht gezogen werden: Systemadministratoren, Intelligence-Ressourcen, Eskalationsressourcen, Compliance-Beauftragte, Management / Supervision

SOC-Mitarbeiter

Die Job-Rollen in einem SOC entwickeln sich schnell weiter.

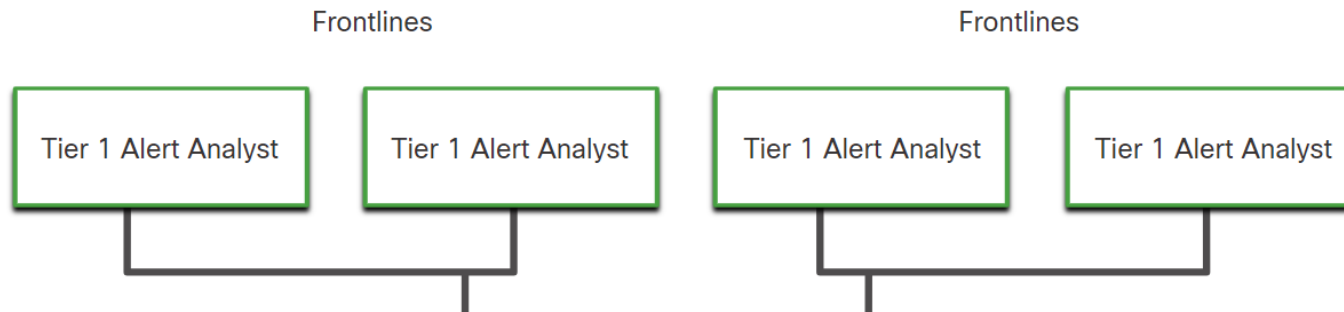
Traditionell ordnen SOCs Job-Rollen nach Stufen zu, je nach den erforderlichen Fachkenntnissen und Verantwortlichkeiten für jede Stufe.

Jobs der ersten Ebene sind eher Einstiegsjobs, während Jobs der dritten Ebene umfangreiches Fachwissen erfordern.



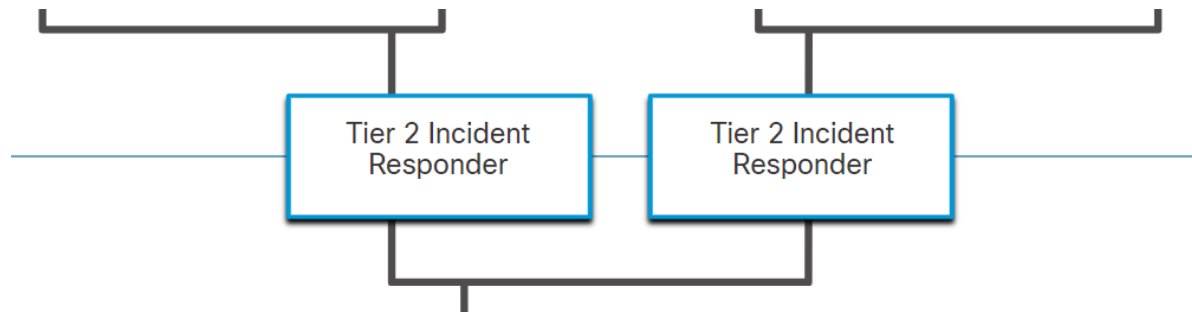
Tier 1 Alert Analyst

- Sie bilden die erste Verteidigungslinie
- Diese Fachleute überwachen die eingehenden Alarme, überprüfen, ob ein echter Vorfall vorliegt (Einschätzung) und leiten Tickets bei Bedarf an Tier 2 weiter.



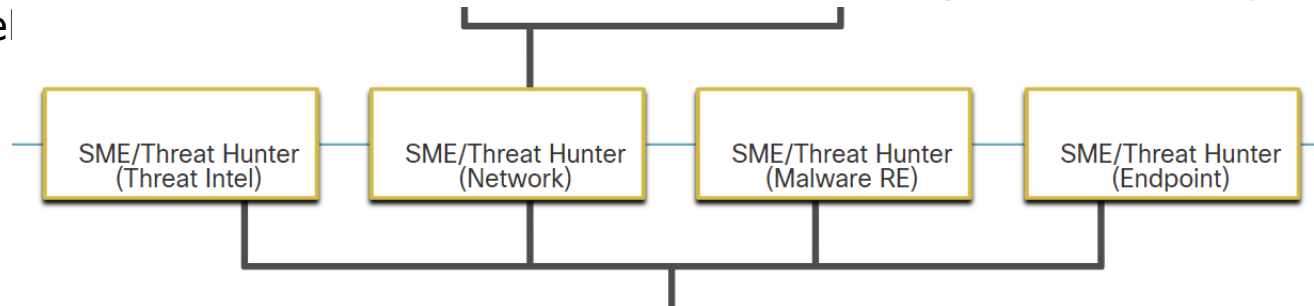
Tier 2 Incident Responder

- Diese Fachleute sind für die gründliche Untersuchung von Vorfällen verantwortlich und raten zu Abhilfemassnahmen oder zu ergreifende Abwehrmassnahmen (Mitigierung) im Incident Response bzw. ergreifen diese Massnahmen selbst.



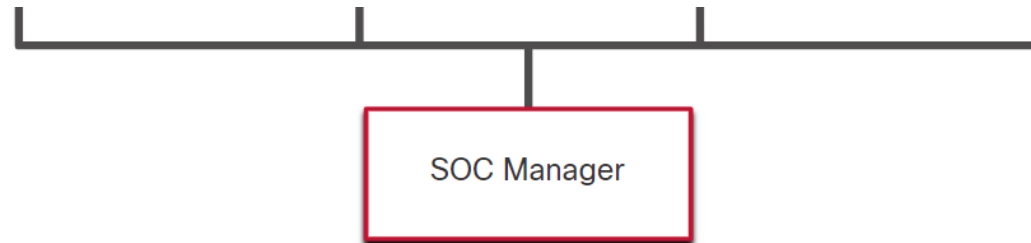
Tier 3 Threat Hunter

- Diese Fachleute verfügen über Expertenwissen in den Bereichen Netzwerk, Endpunkt, Threat Intelligence und Reverse Engineering von Malware und weiteren Themenfelder (z.B. Cyber Defense Strategy).
- Sie sind Experten darin, die Prozesse der Malware nachzuvollziehen, um ihre Auswirkungen zu bestimmen und herauszufinden, wie sie entfernt werden kann. Sie sind auch intensiv an der Jagd nach potenziellen Bedrohungen und der Implementierung von Tools zur Bedrohungserkennung beteiligt.
- Threat Hunters suchen nach noch nicht erkannten Cyber-Bedrohungen in der IT-Umge|

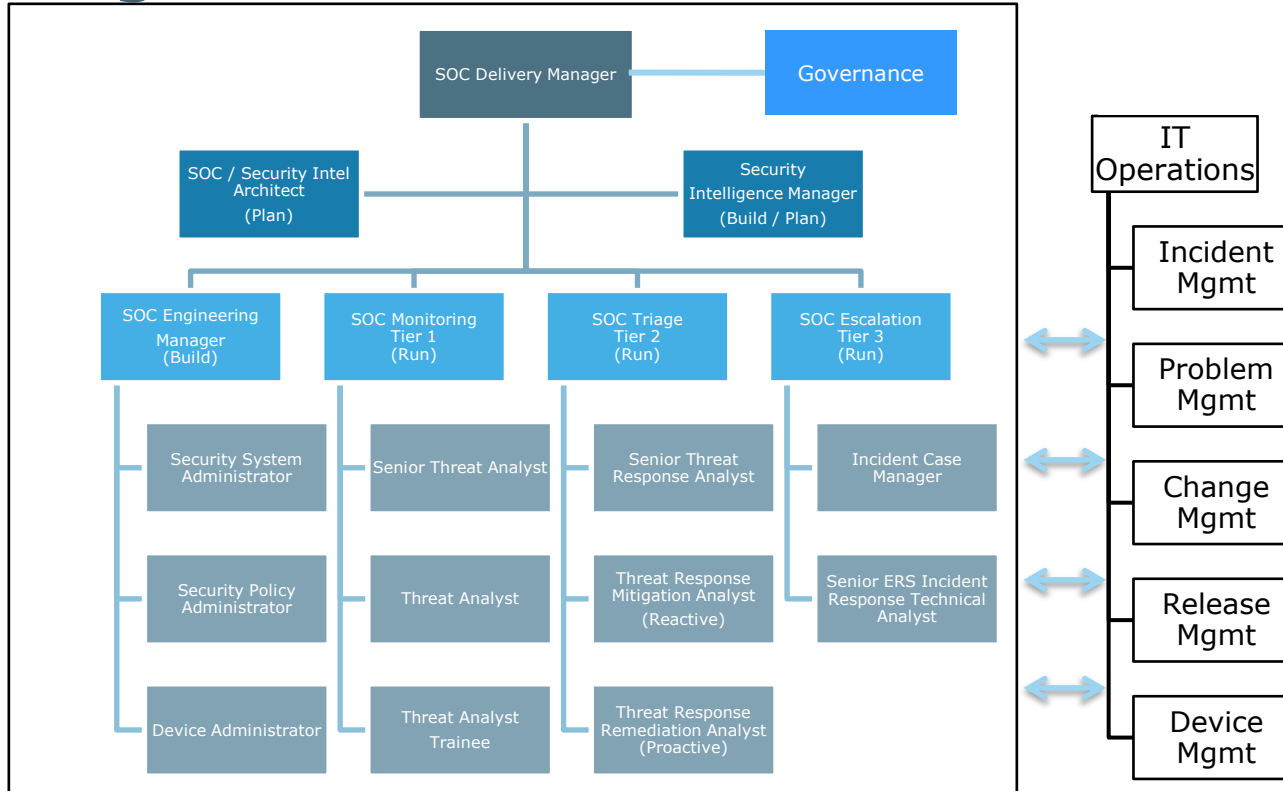


SOC-Manager

- Dieser Fachmann verwaltet alle Ressourcen des SOC und dient als Ansprechpartner für die grössere Organisation oder den Kunden.
- Rapportiert üblicherweise dem CIO oder dem CISO



SOC-Organisation



SOC-Rollen und Verantwortlichkeiten (detailliert)

		SOC Analyst: Monitoring	SOC Analyst: Triage	SOC Analyst: Response	Security Intelligence Analyst	Security Incident Handler (Certified)	SOC Tools Admin	SOC Manager	Security Forensic Analyst	IT Security Admin	IT Operations	CERT
Core Security Services	Security Monitoring	R	C					A				
	Incident Triage	C	R	C				A				
	Incident Response	C	C	R	C	R		A		R	I	
	Delivery Management							A			I	
Deployment Services	Use Case Design	C	C	C	R		C	A		C	C	
	Log Source Acquisition	R			C		R	A		C	C	
	Service Testing & Tuning						R	A		I	I	
	Custom Playbook Development	C	C	C	R	C	C	A		C	C	
	Operations Training	C	C	C	R		C	A				
Security Intelligence Services	Security Intelligence Analysis	C	C	C	A			C		C	C	
	Security Intelligence Briefings				A			C		C	C	
	Use Case Recommendations	C	C	C	A			C		C	C	
Administrative Services	SIEM Administration						R	A		I	I	
	Contextual Data Management				C		R	A		C	C	
	Log Source Management				C		R	A		C	C	
	Log Source Heartbeat Monitoring	C					R	A		C	C	
Reporting Services	Security Reporting	C	C	C	C	C		A		C	I	
	Efficiency Reporting	C	C	C				A		C	I	
	Financial Reporting	C	C	C		C		A			I	
Optional Services	Enterprise Incident Management					C						A
	Forensics Investigation	C	C	C		C		C	A	C	C	
	Policy Violation Handling	C	C	C			C			A	C	

Responsible – Informed – Accountable – Consulted

Weitere Aufgaben Mitarbeiter

- Fortlaufende Weiterbildung, sei es im Job, durch externes Training oder bei produkte-spezifischen Schulungen

- Zertifizierungen:

- Die **Cisco Certified CyberOps Associate/Professional**-Zertifizierung bietet einen wertvollen ersten Schritt zum Erwerb der Kenntnisse und Fähigkeiten, die für die Arbeit in einem SOC-Team erforderlich sind. Sie kann ein wertvoller Bestandteil einer Karriere im spannenden und wachsenden Bereich der Cybersecurity Operations sein.
(<https://www.cisco.com/c/en/us/training-events/training-certifications/certifications/associate/cyberops-associate.html>
<https://www.cisco.com/c/en/us/training-events/training-certifications/certifications/professional/cyberops-professional.html>)
- Die **CompTIA Cybersecurity Analyst (CySA+)**-Zertifizierung ist eine herstellerunabhängige IT-Fachmann-Zertifizierung. Sie bestätigt die Kenntnisse und Fähigkeiten, die erforderlich sind, um Tools zur Erkennung von Bedrohungen zu konfigurieren und zu verwenden, Datenanalysen durchzuführen und die Ergebnisse zu interpretieren, um Schwachstellen, Bedrohungen und Risiken für eine Organisation zu identifizieren. Das Endziel ist die Fähigkeit, Anwendungen und Systeme innerhalb einer Organisation zu sichern und zu schützen.
(<https://www.comptia.org/en/certifications/cybersecurity-analyst/>)



Weitere Aufgaben Mitarbeiter (2)



- **SANS** bietet intensive, praxisnahe Schulungen rund um das Thema Cyber Security mit Labs, Materialien und Trainern. (<https://www.sans.org/cyber-security-courses>)

Zertifizierungsstellen

- **GIAC** wurde 1999 gegründet und ist eine der ältesten Sicherheitszertifizierungsorganisationen. Sie bietet eine breite Palette von Zertifizierungen in sieben Kategorien an. (<https://www.giac.org/>)
- **(ISC)²** ist eine internationale Non-Profit-Organisation, die die CISSP-Zertifizierung anbietet. Sie bietet eine Reihe weiterer Zertifizierungen für verschiedene Spezialgebiete der Cybersicherheit an. (<https://www.isc2.org/>)

Gute Übersicht: <https://pauljerimy.com/security-certification-roadmap/>

Beispiel: Job Description - Triage Analyst

Responsibilities

- Monitoring of security events received through alerts from SIEM or other security tools
- Review alerts escalated by end users
- Handel end user and security services consumer initiated incidents and initiating trouble tickets – Sev 4 tickets
- Performing Level 1 triage of incoming issues (initial assessing the priority of the event, initial determination of incident to determine risk and damage or appropriate routing of security or privacy data request)
- Monitoring of alert and downstream dependencies health (logger, client agents, etc)
- Responsible for troubleshooting agents and logs required for reporting when not reporting to alerting systems
- Intake intelligence actions from Intelligence teams and ticket for appropriate operators for tool policy or tool setting tuning
- Provide limited incident response to end users for low complexity security incidents
- Notifying appropriate contact for security events and response
- Takes an active part in the resolution of incidents, even after they are escalated
- Work assigned ticket queue
- Understanding and exceeding all tasked SLA commitments
- Track and report on closure of tickets per SLAs
- Escalating issues to Tier II or management when necessary
- Provide daily and weekly metrics for security and vulnerability incidents
- 24/7 Shift work required

Experience and Skills

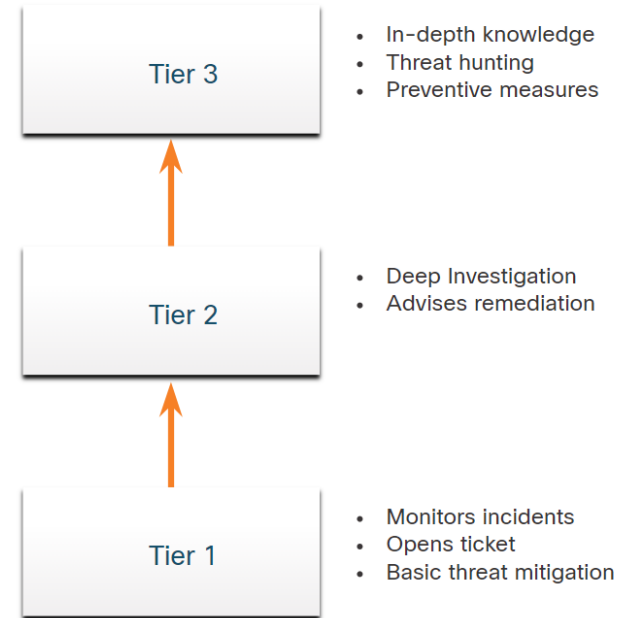
- Process and Procedure adherence
- General network knowledge, TCP/IP Troubleshooting
- Ability to trace down an endpoint on the network based on ticket information
- Familiarity with system log information and what it means
- Understanding of common network services (web, mail, DNS, authentication)
- Knowledge of host-based firewalls, Anti-Malware, HIDS
- General Desktop OS and Server OS knowledge
- TCP/IP, Internet Routing, UNIX & Windows NT
- Strong analytical and problem

Training

- Required: Security Essentials – SEC401 (optional GSEC certification)
- Computer Forensic Investigation – Windows In-Depth - FOR408
- Recommended: Security Incident Handling and Forensic - FOR 508

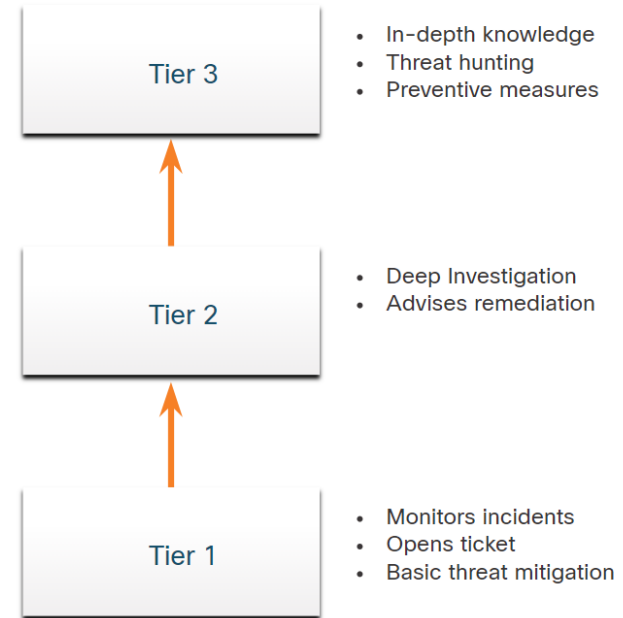
Prozesse im SOC

- Der Tag eines Cybersecurity-Analysten beginnt in der Regel mit der Überwachung der Warteschlangen mit Sicherheitswarnungen.
- Häufig wird ein Ticketing-System verwendet, um Alarme einer Warteschlange zuzuweisen, die ein Analyst untersuchen soll.
- Da die Software welche die Alarme generiert, falsche Alarme (**false positive**) auslösen kann, kann eine Aufgabe des Cybersecurity Analysten darin bestehen, zu überprüfen, ob ein Alarm einen echten Sicherheitsvorfall darstellt.
- Wenn dies der Fall ist, kann der Vorfall an Ermittler oder anderes Sicherheitspersonal weitergeleitet werden, um darauf zu reagieren. Andernfalls kann der Alarm als Fehlalarm abgetan werden.

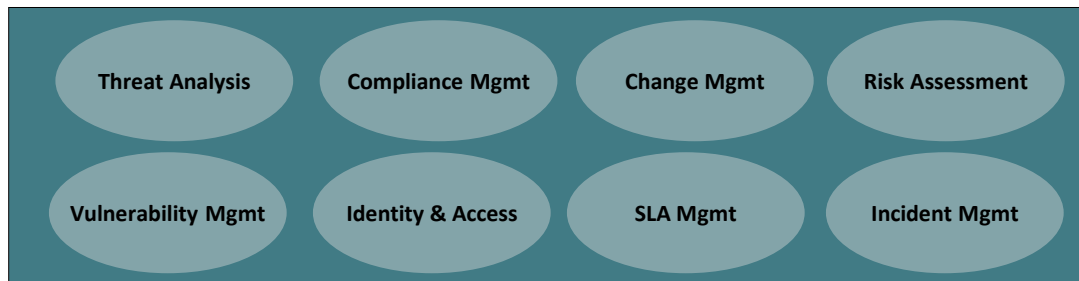


Prozesse im SOC

- Wenn ein Ticket nicht gelöst werden kann, leitet der Cybersecurity-Analyst das Ticket an einen Tier 2 Incident Responder zur tieferen Untersuchung und Behebung weiter.
- Wenn auch der Incident Responder das Ticket nicht lösen kann, wird es an Mitarbeiter der Stufe 3 weitergeleitet, die über vertiefte Kenntnisse und Fähigkeiten zur Bedrohungsjagd (Threat Hunting) verfügen.



weitere Prozesse im SOC



- SOC-Prozesse müssen dokumentiert und konsistent implementiert sein und auf bestehenden Standards / Governance-Frameworks basieren. Die Verfahren müssen die Sicherheitsrichtlinien des Unternehmens, die Geschäftskontrollen und die relevanten regulatorischen Anforderungen berücksichtigen.

Zu beachten:

- Die Aufgaben des SOC müssen klar definiert sein - Incident Discovery, CERT, etc.
- SOC's unterscheiden sich von NOCs, und ein Alarm ist nicht immer gleichbedeutend mit einer Aktion.
- Die Prozesse müssen die Bewertung und Einbeziehung eines sich ständig ändernden Stroms potenziell verwertbarer Bedrohungsdaten berücksichtigen.
- Best Practices für die Untersuchung von Vorfällen, die Reaktion darauf und die Schadensbegrenzung müssen beibehalten und aktualisiert werden, wenn neue Technologien hinzukommen, sich ändern oder weiterentwickelt werden.



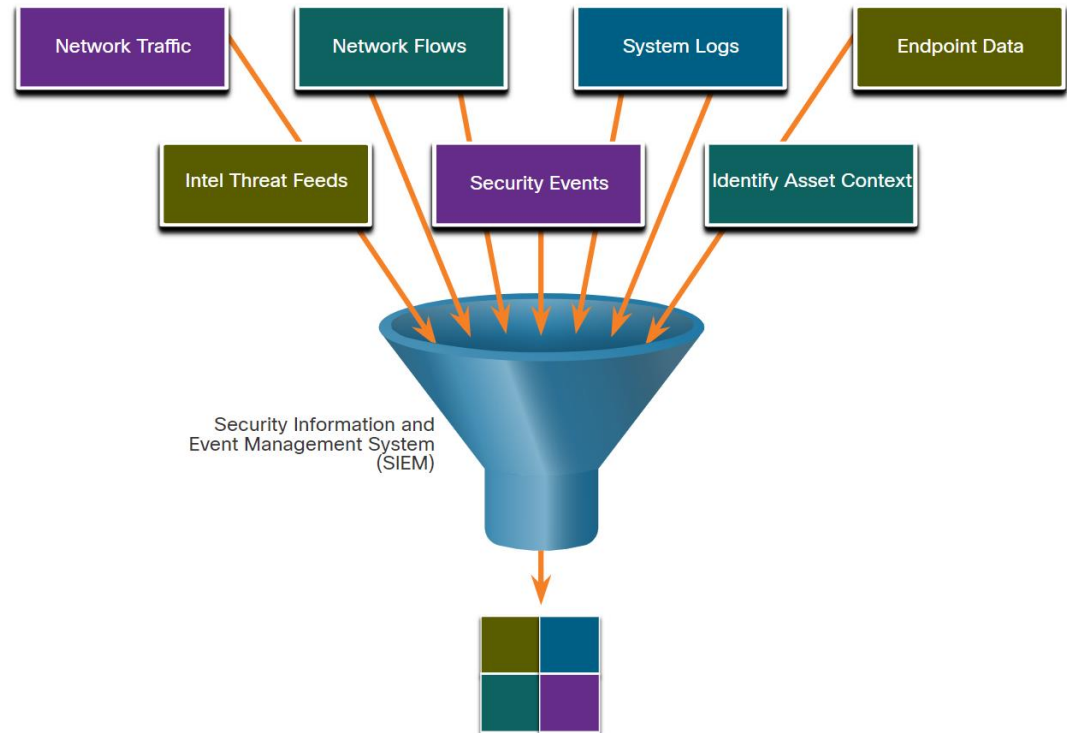
Technologien im SOC: SIEM

SIEM = Security Information and Event Management

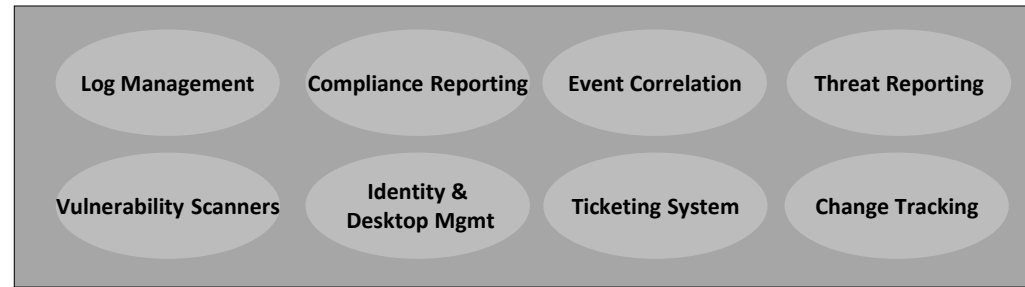
- Wie in der Abbildung dargestellt, benötigt ein SOC ein Sicherheitsinformations- und Ereignisverwaltungssystem (SIEM) oder ein entsprechendes Äquivalent. SIEM macht Sinn aus all den Daten, welche Firewalls, sonstige Netzwerk-Appliances, Intrusion-Detection-Systeme und andere Geräte erzeugen.
- SIEM-Systeme werden zum Sammeln und Filtern von Daten, zum Erkennen und Klassifizieren von Bedrohungen sowie zum Analysieren und Untersuchen von Bedrohungen verwendet. SIEM-Systeme können auch Ressourcen verwalten, um Präventivmassnahmen zu implementieren und zukünftigen Bedrohungen zu begegnen.

SOC Monitoring System

- SOC-Technologien umfassen eine oder mehrere der folgenden Möglichkeiten:
 - Event collection, correlation, and analysis
 - Security monitoring
 - Security control
 - Log management
 - Vulnerability assessment
 - Vulnerability tracking
 - Threat intelligence



Technologien im SOC (detaillierter)



- Die Technologie für den Aufbau eines SOC ist die Grundlage, auf der die Organisation die Fähigkeit demonstriert, kontinuierlich Sicherheit zu bieten, auch in Zeiten von Zwängen wie anhaltenden Angriffen, Naturkatastrophen, Anlagenausfällen usw.

Zu beachten:

- SOC-Technologien (SIEM, Trouble Ticketing, Incident Management, etc.) sind aufgrund ihrer Gesamtkomplexität oft zweckgebunden, kostspielig und schwierig zu warten
- Die Anzahl der unterschiedlichen Systeme und die Menge der Geräte-bzw. Ereignisdaten erfordern in der Regel ein spezielles IT-Personal für die Systemadministration
- Das Kapazitätsmanagement kann eine Herausforderung sein, da Spitzenlasten wie DDoS, monatliche Batch-Verarbeitung usw. unterstützt werden müssen.
- Die Verwaltungs- und Berichtssysteme müssen flexibel genug sein, um Prozess- und Sicherheitsrichtlinien sowie Änderungen in der Technologielandschaft zu berücksichtigen

Technologien im SOC: SOAR



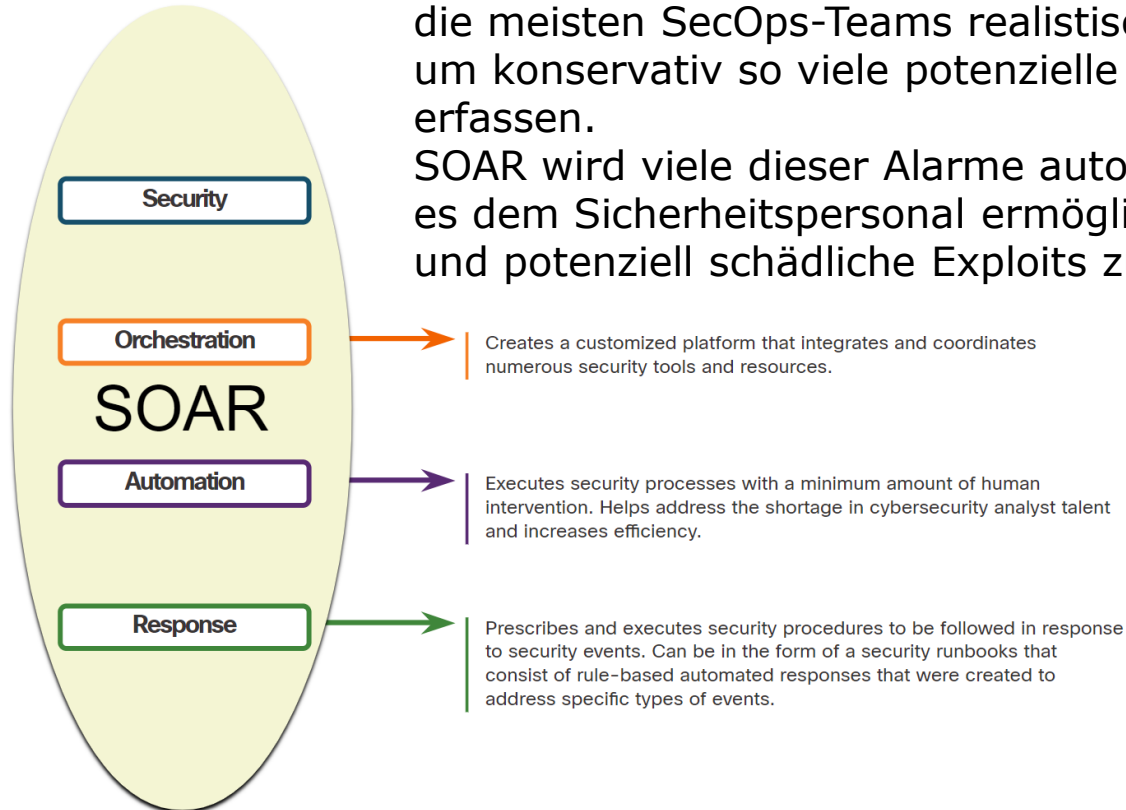
- SIEM und Security Orchestration, Automation and Response (SOAR) werden oft miteinander kombiniert, da sie über Fähigkeiten verfügen, die sich gegenseitig ergänzen.
- Grosse Security Operations (SecOps)-Teams nutzen beide Technologien, um ihr SOC zu optimieren. Es wird geschätzt, dass 15 % der Organisationen mit einem Sicherheitsteam von mehr als fünf Mitarbeitern bis Ende 2020 SOAR einsetzen werden.
- SOAR-Plattformen ähneln SIEMs insofern, als sie Alarmer aggregieren, korrelieren und analysieren. Die SOAR-Technologie geht jedoch einen Schritt weiter, indem sie Bedrohungsdaten integriert und Arbeitsabläufe zur Untersuchung von Vorfällen und zur Reaktion darauf automatisiert, die auf vom Sicherheitsteam entwickelten Playbooks/Runbooks basieren.

SOAR



- SOAR-Sicherheitsplattformen:
 - Sammeln Alarmdaten von jeder Komponente des Systems.
 - Stellen Werkzeuge bereit, mit denen Fälle recherchiert, bewertet und untersucht werden können.
 - Betonen die Integration als Mittel zur Automatisierung komplexer Incident-Response-Workflows, die eine schnellere Reaktion und adaptive Verteidigungsstrategien ermöglichen.
 - Enthalten vordefinierte Playbooks, die eine automatische Reaktion auf bestimmte Bedrohungen ermöglichen. Playbooks können automatisch auf der Grundlage vordefinierter Regeln initiiert oder vom Sicherheitspersonal ausgelöst werden.
- SOAR legt den Schwerpunkt auf Integrationswerkzeuge und die Automatisierung von SOC-Workflows. Es orchestriert viele manuelle Prozesse, wie z. B. die Untersuchung von Sicherheitswarnungen, die nur bei Bedarf menschliches Eingreifen erfordern. Dadurch wird das Sicherheitspersonal entlastet und kann sich um dringendere Angelegenheiten und High-End-Untersuchungen sowie die Beseitigung von Bedrohungen kümmern. Der zukünftige Einsatz von hochentwickelten SOAR-Plattformen wird die SOC-Operationen und Job-Rollen neu gestalten.

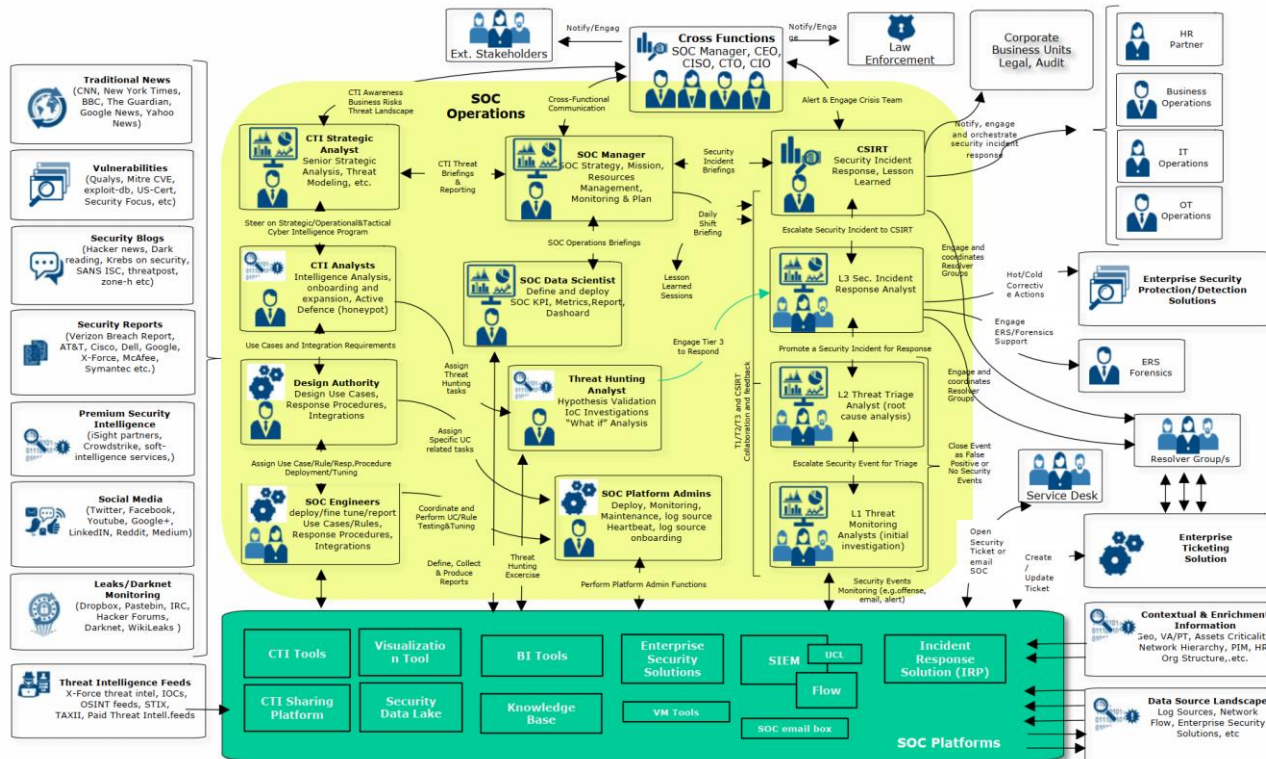
SOAR



SIEM-Systeme produzieren zwangsläufig mehr Alarme, als die meisten SecOps-Teams realistisch untersuchen können, um konservativ so viele potenzielle Exploits wie möglich zu erfassen.

SOAR wird viele dieser Alarme automatisch verarbeiten und es dem Sicherheitspersonal ermöglichen, sich auf komplexere und potenziell schädliche Exploits zu konzentrieren.

Wenn alles nur so einfach wäre...





SOC Metriken

- Ein SOC ist von entscheidender Bedeutung für die Sicherheit einer Organisation. Unabhängig davon, ob es sich um ein internes oder um ein externes SOC handelt, das Dienstleistungen für mehrere Organisationen erbringt, ist es wichtig zu verstehen, wie gut das SOC funktioniert, damit Verbesserungen an den Mitarbeitern, Prozessen und Technologien, aus denen das SOC besteht, vorgenommen werden können.
- Es können viele Metriken oder **Key Performance Indicators** (KPI) entwickelt werden, um verschiedene spezifische Aspekte der SOC-Leistung zu messen. Fünf Metriken werden üblicherweise als SOC-Metriken verwendet. Es ist jedoch zu beachten, dass Metriken, die eine pauschale Leistung beschreiben, aufgrund der Vielfalt der Cybersicherheitsbedrohungen häufig kein genaues Bild des SOC-Betriebs zeichnen.



SOC Metriken (1)

Einige gängige Metriken, die von SOC-Managern zusammengestellt werden, sind (hier am Beispiel Zeitmetriken):

- **Dwell Time** (Verweilzeit) - die Zeitspanne, in der Bedrohungsakteure Zugriff auf ein Netzwerk haben, bevor sie entdeckt werden und ihr Zugriff gestoppt wird.
- **Mean Time to Detect (MTTD)** - die durchschnittliche Zeit, die das SOC-Personal benötigt, um gültige Sicherheitsvorfälle im Netzwerk zu erkennen.
- **Mean Time to Respond (MTTR)** - die durchschnittliche Zeit, die benötigt wird, um einen Sicherheitsvorfall zu stoppen und zu beheben.
- **Mean Time to Contain (MTTC)** - die Zeit, die benötigt wird, um den Vorfall davon abzuhalten, weiteren Schaden an Systemen oder Daten zu verursachen.
- **Time to Control** - die Zeit, die benötigt wird, um die Ausbreitung von Malware im Netzwerk zu stoppen.

SOC Metriken (2)

Weiter gibt es z.B. Volumen- und Effizienzmetriken:

- **Anzahl Incidents/Tickets**: Gesamtzahl pro Periode, aufgeteilt nach Schweregrad (Low/Medium/High/Critical).
- **Incident Closure Rate (ICR)**: Anteil gelöster Incidents (Ziel: 80-95%).
- **False Positive Rate (FPR)**: Anteil falscher Alarme (Ziel: <20%).
- **Alerts pro Analysten**: Belastungsmessung (Ziel: 50-100/Tag pro Tier 1).
- Sowie Qualitäts- und Reife-Metriken:

Metrik	Beschreibung	Zielwert
Threat Detection Rate	% erkannter bekannter Bedrohungen	>95%
Incident Escalation Rate	% von Tier 1 → Tier 2/3	<30%
Coverage Rate	% Assets mit Monitoring	100%
Mean Time Between Failures (MTBF)	Zeit zwischen Detection-Fehlern	>30 Tage

Tipp: Starte mit den "Big 4" (MTTD, MTTR, FPR, ICR) und erweitere basierend auf SOC-Reife. Dashboards (z.B. Splunk, Elastic) automatisieren Tracking.

Security vs. Availability



- Die meisten Unternehmensnetzwerke müssen zu jeder Zeit betriebsbereit sein. Das Sicherheitspersonal weiss, dass die Netzwerkverfügbarkeit aufrechterhalten werden muss, damit das Unternehmen seine Prioritäten erfüllen kann.
- Jedes Unternehmen oder jede Branche hat eine begrenzte Toleranz für Netzausfallzeiten. Diese Toleranz basiert in der Regel auf einem Vergleich der Kosten für die Ausfallzeit im Verhältnis zu den Kosten für die Absicherung gegen Ausfallzeiten.
- In einem kleinen Einzelhandelsunternehmen mit nur einem Standort kann es beispielsweise tolerierbar sein, einen Router als **Single Point of Failure** zu haben. Wenn jedoch ein grosser Teil des Umsatzes dieses Geschäfts von Online-Käufern stammt, kann der Eigentümer beschliessen, ein gewisses Mass an Redundanz bereitzustellen, um sicherzustellen, dass eine Verbindung immer verfügbar ist.

Security vs. Availability

- Die bevorzugte Betriebszeit wird oft in der Anzahl der Ausfallminuten pro Jahr gemessen, wie in der Tabelle dargestellt. Eine Betriebszeit von "fünf Neunen" bedeutet zum Beispiel, dass das Netzwerk 99,999 % der Zeit in Betrieb ist oder nicht mehr als 5 Minuten pro Jahr ausfällt. "Vier Neunen" würde eine Ausfallzeit von 53 Minuten pro Jahr bedeuten.
- Die Sicherheit darf jedoch nicht so stark sein, dass sie die Bedürfnisse der Mitarbeiter oder Geschäftsfunktionen beeinträchtigt.
Es ist immer ein Kompromiss zwischen starker Sicherheit und der Ermöglichung effizienter Geschäftsabläufe.

Availability %	Downtime
99.8%	17.52 hours
99.9% ("three nines")	8.76 hours
99.99% ("four nines")	52.56 minutes
99.999% ("five nines")	5.256 minutes
99.9999% ("six nines")	31.56 seconds
99.99999% ("seven nines")	3.16 seconds

SOC Strategien

Die Auswahl des optimalen SOC-Betriebsmodells hängt von der Abwägung der geschäftlichen und technischen Anforderungen, des Risikos und der finanziellen Beschränkungen ab



SOC-Betriebsmodelle

Owned SOC	Managed SOC	Hybrid SOC
Unternehmung betreibt ihr eigenes SOC	Unternehmung kauft komplette SOC-Dienstleistungen ein	Teile des SOC werden aus der Unternehmung ausgelagert
Gute Integration in Unternehmung und internen Security Prozesse möglich	Kann professionelle Dienstleistung erwarten (man weiss was man kriegt – vertragliche Abmachungen)	ev. besser skalierbar, für Bereiche die nicht intern abgedeckt werden können, höhere Flexibilität
Aufwendig (24/7), benötigt entsprechende Personalressourcen (sofern man die findet)	Aufwendiges Onboarding, Wechsel könnte aufwendig und teuer werden	Abstimmungs- und Koordinationsbedarf, wer macht was?

Wie kommt man zu einem SOC?

Zu Beginn sollte die Organisation bei der Festlegung ihrer Ziele die folgenden Fragen berücksichtigen

- Was ist der primäre Zweck des SOC?
- Welche spezifischen Aufgaben sind dem SOC zugewiesen? (z. B. Bedrohungsanalyse, Verwaltung von Sicherheitsgeräten, Compliance-Management, Aufdeckung von Insider-Missbrauch in Finanzsystemen, Reaktion auf Vorfälle und forensische Analysen, Schwachstellenbewertungen usw.)
- Wer sind die Nutzer der vom SOC gesammelten und analysierten Informationen? Welche Anforderungen haben diese an das SOC?
- Wer ist der letztendliche Stakeholder für das SOC? Wer wird das SOC an den Rest der Organisation "verkaufen"?
- Welche Arten von Sicherheitsereignissen werden letztendlich in das SOC zur Überwachung eingespeist?
- Wird die Organisation einen externen Partner suchen, der sie bei der Verwaltung des SOC unterstützt?

Bedeutung eines SOC

- Anzahl und schwere der Bedrohungen nehmen laufend zu
→ effektives Mittel das "dagegenhält"
- Zentrale Koordinations- und Aktivitätsstelle
→ effizientere Arbeit
- Vernetzt
→ Cyber Threat Intelligence & OSINT
- Zeigt Risiken auf und minimiert sie



Bildquelle: <https://www.qrcsolutionz.com/certification/soc>

Quellen, Organisationen und Literatur

- MITRE - ATTACK Enterprise Navigator <https://attack.mitre.org/>
- MITRE Institute <https://www.mitre.org/news-insights>
- SANS Institute <https://www.sans.org>
- NIST National Institute of Standards and Technology <https://www.nist.gov>
- GIAC Global Information Assurance Certification <https://www.giac.org>
- IBM X-Force Exchange <https://exchange.xforce.ibmcloud.com>
- Security Intelligence <https://securityintelligence.com>
- Splunk SIEM Hersteller Blog: https://www.splunk.com/de_de/blog/security/splunk-enterprise-security-handlungsfreiheit-fuer-das-gesamte-soc.html
- ...